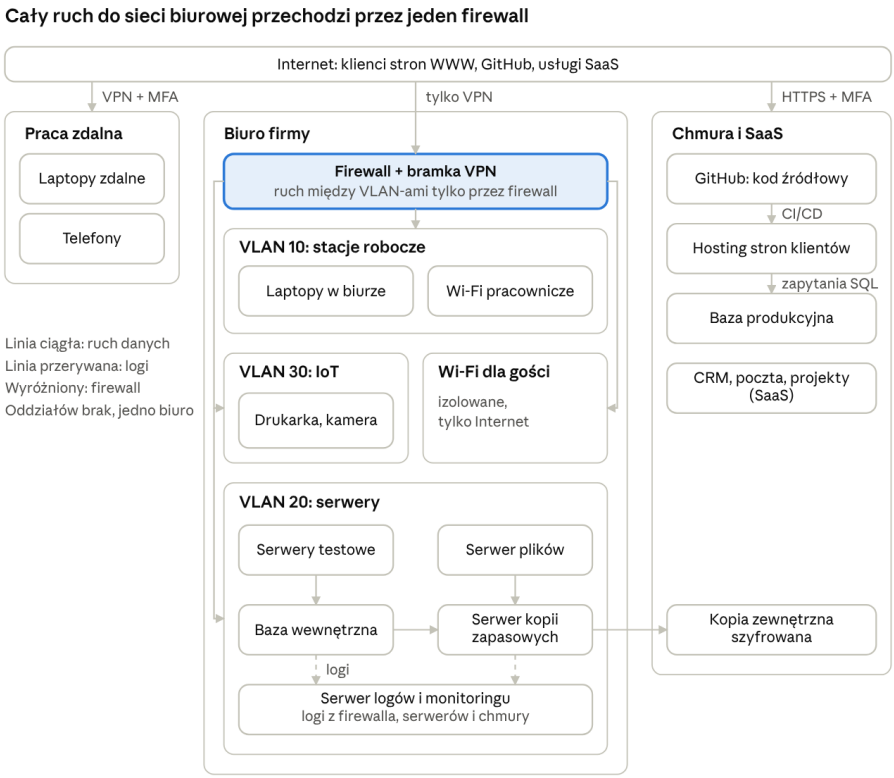
Zajęcia 3: Architektura środowiska i projekt zabezpieczeń

Witchak Modeling, zespół: M. Szyksznia, K. Witczak, O. Wilk, I. Skrypnyk

Opisujemy firmę 10-osobową pracującą hybrydowo. Przyjęliśmy: jedno biuro bez oddziałów, urządzenia IoT to drukarka i kamera, produkcyjne strony i baza klientów są w chmurze, kod w GitHub, CRM i poczta jako SaaS, a kopie zapasowe w biurze i w chmurze (stan docelowy).

Zadanie 1. Diagram środowiska IT



Zadanie 2. Przepływy informacji

Przepływ	Przechowywanie, droga i dostęp	Możliwe naruszenie
Klient → strona WWW → baza produkcyjna	Baza w chmurze hostingowej, HTTPS. Dostęp: aplikacja, administrator baz, DevOps.	SQL Injection, przestarzała baza, wyciek hasła do bazy.
Pracownik zdalny → VPN → serwer plików i serwery testowe	Serwery w biurze (VLAN 20), tunel VPN. Dostęp według grup projektowych.	Przejęte hasło do VPN, skradziony laptop, zbyt szerokie uprawnienia.
Programista → GitHub → hosting	Repozytoria w GitHub, HTTPS lub SSH. Dostęp: programiści, Tech Lead, konto CI/CD.	Wyciek kodu, klucze w repozytorium, przejęte konto GitHub.
Serwery → serwer kopii → chmura	Kopie w biurze i w chmurze, kanał szyfrowany. Dostęp: konto serwisowe i administrator.	Ransomware szyfruje także kopie, brak testu odtwarzania.

Zadanie 3. Zabezpieczenia

Zabezpieczenie	Zastosowanie i zagrożenie, któremu zapobiega	Ryzyka
MFA	Konta administratorów, VPN, GitHub, chmura i poczta: ogranicza przejęcie konta po wycieku hasła.	R3, R5, R7, R8
Segmentacja sieci i firewall	VLAN-y (stacje, serwery, IoT), osobne Wi-Fi dla gości, zasada "domyślnie blokuj": zatrzymuje ruch boczny z zainfekowanego laptopa lub drukarki do serwerów.	R4, R9, R12

Zabezpieczenie	Zastosowanie i zagrożenie, któremu zapobiega	Ryzyka
VPN	Zdalny dostęp tylko przez VPN i według grup: ogranicza podsłuch i zbyt szeroki dostęp zdalny.	R8, R9
Szyfrowanie	Dyski laptopów, kopia zewnętrzna i baza: chroni dane po kradzieży laptopa lub wycieku kopii.	R1, R3, R13
Kopie zapasowe	Zasada 3-2-1, jedna kopia offline, test odtwarzania co kwartał: pozwala odzyskać dane po awarii i ransomware.	R4, R11
Kontrola dostępu i najmniejsze uprawnienia	Uprawnienia według grup projektowych, konta aplikacji bez praw administratora bazy: ogranicza skutki SQL Injection i kradzież kodu.	R1, R2
Konta administratorów	Osobne konta administracyjne, bez kont współdzielonych: jedno przejęte konto nie daje pełnej kontroli.	R7
Monitoring i logowanie	Centralne logi z firewalla, serwerów i chmury oraz alerty: skraca czas wykrycia ataku.	R14
Aktualizacje i stacje robocze	Miesięczne aktualizacje, EDR, brak praw administratora u użytkowników, szkolenie z phishingu: zmniejsza ryzyko infekcji i wykorzystania znanych podatności.	R1, R3, R4
Kontrola kodu i sekretów	Ochrona gałęzi głównej, skanowanie sekretów w GitHub: zapobiega złośliwym zmianom i wyciekowi haseł z repozytorium.	R2, R10
Konfiguracja chmury i telefonów	Lista kontrolna, brak domyślnych haseł, blokada ekranu i zdalne wylogowanie: zapobiega ujawnieniu danych przez błędną konfigurację lub zgubiony telefon.	R5, R15
Dokumentacja i zastępstwa	Dwie osoby znają każdy krytyczny system: ogranicza skutki odejścia pracownika.	R16

Zadanie 4. Nowe ryzyka w rejestrze

Ryzyka R1 do R6 z poprzednich zajęć bez zmian. Diagram ujawnił 10 nowych (poziom = prawdopodobieństwo × skutek, skala 1 do 5).

ID	Nowe ryzyko	Praw.	Skutek	Poziom
R7	Przejęcie konta administratora i pełna kompromitacja infrastruktury	3	5	15
R8	Atak na VPN lub dostęp zdalny	3	5	15
R9	Ruch boczny w sieci z powodu braku segmentacji	3	4	12
R10	Wyciek haseł i kluczy API z repozytorium GitHub	4	4	16
R11	Ransomware szyfruje serwer plików i kopie zapasowe	3	5	15
R12	Przejęcie urządzeń IoT z domyślnymi hasłami	3	3	9
R13	Kradzież lub zgubienie laptopa bez szyfrowania dysku	3	4	12
R14	Atak niewykryty z powodu braku monitoringu	4	3	12
R15	Dostęp do poczty i CRM z niezabezpieczonych telefonów	3	3	9
R16	Utrata wiedzy po odejściu kluczowego pracownika	3	4	12

Zaktualizowane TOP 5: R1 (20), R3, R5 i R10 (po 16). Piąte miejsce dzielą R2, R4, R7, R8 i R11 (po 15), więc zespół musi wybrać jedno z nich.